Deliverable 2 of 7

Literature Review

AWS Threat Detection, Monitoring, Incident Response & Forensics

DEPI – AWS Security Cloud Computing Track – Project 4

#	Team member	Role
1	Kareem Mohamed Abdalmged	Team Lead, IaC & Documentation
2	Adham Ramzy Mohamed Eltohamy	Threat Detection Engineer
3	Hossam Abdelghany Mostafa	Incident Response & Forensics Engineer
4	Alaa Ahmed Ramadan	Logging & Audit Engineer
5	Amira Ashraf Saber	Automation & Reporting Engineer

Instructor: Ahmed Gamal | Submission due: 16 October 2026 | Version 1.0

1. Purpose

This review summarises the industry frameworks and AWS guidance that shape the project's design, compares the main design alternatives, and records the instructor's evaluation, suggested improvements and grading criteria as required by the DEPI documentation guidelines. Sections 5 to 7 are completed together with the instructor.

2. Reference Frameworks and Guidance

Source	What it covers	How the project applies it
AWS Well-Architected Framework – Security Pillar	Design principles: enable traceability, automate security best practices, prepare for security events; detective controls (logging, monitoring) and incident response practices.	Logging foundation (Week 1), detection services (Week 2), IR preparation and simulation (Week 3), automated response (Week 4).
AWS Security Incident Response Guide	Incident response in AWS: preparation, detection and analysis, containment, eradication, recovery and post-incident activity; common incident types.	Structure of the three IR playbooks (EC2, access keys, S3), containment checklist, lessons learned.
AWS Security Reference Architecture (AWS SRA)	Placement of security services in a multi-account environment, including a Log Archive account, organization trail and delegated administration of GuardDuty and Security Hub.	Guides the central log-archive bucket, the organization trail and where detection services are administered.
AWS Prescriptive Guidance – Forensic investigation environment strategies in the AWS Cloud	Approaches to acquiring, storing and analysing evidence: snapshots, isolated forensic environments, access control over evidence.	EBS snapshot acquisition, dedicated evidence bucket with restricted access, chain-of-custody notes (Week 3).
Automated Security Response on AWS (AWS Solutions Library) and Security Hub custom actions	SOAR-style pattern: finding → EventBridge → remediation runbook; analyst-triggered response through custom actions.	Pattern for the EventBridge + Lambda + SSM Automation playbooks and the Security Hub custom action (Week 4).
CIS Amazon Web Services Foundations Benchmark	Configuration baseline including logging and monitoring controls, e.g. CloudTrail in all regions with log file validation, AWS Config enabled, VPC Flow Logs, access logging on the CloudTrail bucket.	Checklist for Week 1 and for Config rules / Security Hub standards; KPIs on log coverage.
AWS Foundational Security Best Practices standard (Security Hub)	Automated controls across AWS services, e.g. publicly accessible S3 buckets, unrotated access keys, open security groups.	Standard enabled in Week 2; failed controls are triaged and used as simulation starting points.
NIST SP 800-61 – Computer Security Incident Handling Guide	Incident response life cycle and documentation practices.	Structure of the IR process, the incident timeline and the final IR report.
NIST SP 800-86 – Guide to Integrating Forensic Techniques into Incident Response	Forensic process (collection, examination, analysis, reporting) and preserving data integrity.	Evidence collection procedure and root cause analysis format.
NIST SP 800-92 – Guide to Computer Security Log Management	Log generation, storage, retention, protection and analysis.	Log architecture, retention policy and audit log inventory (Week 1).
RFC 3227 and ISO/IEC 27037 – Evidence collection and digital evidence handling	Order of volatility; identification, collection, acquisition and preservation of digital evidence; chain of custody.	Order of evidence collection, SHA-256 hashing, chain-of-custody form.
MITRE ATT&CK – Cloud (IaaS) matrix	Adversary tactics and techniques observed against cloud environments, e.g. valid accounts, credential access, discovery, exfiltration, impact.	Mapping of triaged GuardDuty / Security Hub findings and simulated incidents to techniques (Week 2).

Source	What it covers	How the project applies it
AWS service documentation – GuardDuty, Security Hub, Detective, Inspector, Macie, Config	Finding types, severity, the AWS Security Finding Format, integrations and event structure.	Enabling services, reading findings, building EventBridge event patterns.

3. Comparison of Design Alternatives

Each decision below reflects the trade-offs described in the sources above, weighed against the project's lab budget.

Decision	Options compared	Chosen	Reason
Audit trail scope	Single-account trail vs organization trail	Organization trail (single-account trail as fallback)	One trail records API activity for all member accounts and member accounts cannot disable it; needs AWS Organizations, so a fallback is documented.
Log storage	CloudWatch Logs only vs S3 only vs both	Both	S3 is cheap for retention and queryable with Athena; CloudWatch Logs adds metric filters and alarms. Retention is set on each.
Log analysis	Athena vs CloudWatch Logs Insights vs OpenSearch	Athena (Logs Insights for quick checks)	Serverless and pay per data scanned, queries S3 directly; an OpenSearch cluster bills hourly.
Configuration tracking	AWS Config vs CloudTrail only	AWS Config	Records configuration history and evaluates rules, showing what changed and when.
Threat detection	GuardDuty vs custom Athena detection only	GuardDuty plus custom Athena hunts	Managed detection from CloudTrail, flow and DNS data with finding types that align to MITRE ATT&CK; custom queries cover gaps.
Findings aggregation	Security Hub vs separate service consoles	Security Hub	Single view in a common format, security standards, custom actions and EventBridge integration.
Investigation	Detective vs manual log queries	Detective together with Athena	Behaviour graphs speed up moving from a finding to a root cause; Athena provides exact evidence. Cost is controlled by short enablement.
Vulnerability and data discovery	Inspector / Macie vs third-party scanners	Inspector, Macie scoped to one test bucket	Native services that feed Security Hub; scoping limits cost.
EC2 containment	Stop / terminate vs isolation security group vs NACL deny	Isolation security group plus NACL deny	Keeps the instance running so volatile data and snapshots can be taken; security group changes do not cut connections that are already tracked, so a NACL rule covers them.
Credential containment	Delete key vs deactivate key with deny policy	Deactivate key, deny policy, revoke sessions, rotate; delete after evidence	Stops use while keeping the key as evidence; temporary role sessions need explicit revocation.
Evidence acquisition and storage	EBS snapshot vs live disk imaging; shared bucket vs dedicated evidence bucket	EBS snapshot into a dedicated versioned evidence bucket (memory capture as concept)	Snapshot is fast and non-intrusive; versioning, restrictive policy and hashes protect integrity; Object Lock in governance mode keeps lab teardown possible.

Decision	Options compared	Chosen	Reason
Response automation	Manual runbook vs Lambda only vs SSM Automation vs Step Functions	EventBridge + Lambda + SSM Automation (Step Functions as improvement)	Matches the project brief; Lambda holds logic (e.g. key deactivation) and SSM Automation gives auditable runbooks (snapshot, security group change).
Trigger model	Fully automatic vs analyst-triggered	Both	Automatic for high-severity findings on tagged lab resources; Security Hub custom action when analyst approval is wanted, limiting false-positive containment.
Notification	SNS email vs chat integration	SNS email	Simple and low cost; chat integration is future work.

4. Gap Analysis

The sources describe logging, detection, forensics and automation individually; few beginner-level references show them working together as one pipeline with measured response times. This project closes that gap by delivering:

- One integrated pipeline: audit logging → detection and triage → containment and forensics → automated response and reporting.
- Test evidence for every control and playbook, measured against the KPIs in the Project Planning document.
- A forensic evidence process (snapshots, hashes, chain of custody) that is rarely shown in introductory AWS material.
- Both technical and executive reporting from the same incident data.
- A reproducible Terraform codebase so the design can be rebuilt and reviewed.

5. Feedback & Evaluation (Lecturer's Assessment)

To be completed during the review meeting with the instructor.

Area	Lecturer's comments	Rating
Project idea and scope		
Architecture and design		
Team organisation and task split		
Documentation quality		
Feasibility within timeline and budget		
Overall		

Reviewed by: _____ Date: _____

6. Suggested Improvements

Enhancements the team has identified for discussion with the instructor; the instructor's suggestions are added to the table.

#	Improvement	Benefit	Status
1	AWS Step Functions orchestration with a human approval step	Controlled, visible multi-step response and safer containment decisions	Proposed
2	Dedicated forensic account with cross-account snapshot sharing	Evidence analysed away from the affected account, stronger separation	Proposed
3	Athena partition projection and table tuning	Lower scan cost and faster queries on large log sets	Proposed
4	Compare custom playbooks with the Automated Security Response on AWS solution	Shows build-vs-adopt trade-offs for SOAR	Proposed
5	Amazon Security Lake with OCSF-normalised logs	Central, normalised security data lake across accounts	Future work
6	Memory acquisition and live forensics on instances	Captures volatile evidence beyond disk snapshots	Future work
7	[Instructor suggestion]		
8	[Instructor suggestion]		

7. Final Grading Criteria

The DEPI guidelines base the final evaluation on documentation, implementation, testing and presentation, including each member's contribution. Marks are to be confirmed by the instructor.

Component	What is assessed	Marks
Documentation	All seven DEPI deliverables, completeness and quality	[ ]
Implementation	Working environment, Terraform code, GitHub history	[ ]
Testing	Test plan, executed test cases, evidence, bug reports	[ ]
Presentation	Final presentation and live demo; each member presents their part	[ ]
Total		[ ]

8. References

1. Amazon Web Services. AWS Well-Architected Framework – Security Pillar. docs.aws.amazon.com/wellarchitected
2. Amazon Web Services. AWS Security Incident Response Guide. docs.aws.amazon.com/security-ir
3. Amazon Web Services. AWS Security Reference Architecture (AWS SRA). docs.aws.amazon.com/prescriptive-guidance
4. Amazon Web Services. Forensic investigation environment strategies in the AWS Cloud (AWS Prescriptive Guidance).
5. Amazon Web Services. Automated Security Response on AWS (AWS Solutions Library) and AWS Security Hub documentation.
6. Amazon Web Services. Documentation for AWS CloudTrail, AWS Config, Amazon GuardDuty, Amazon Detective, Amazon Inspector, Amazon Macie, Amazon EventBridge and AWS Systems Manager Automation. docs.aws.amazon.com
7. Center for Internet Security. CIS Amazon Web Services Foundations Benchmark. cisecurity.org
8. NIST. SP 800-61: Computer Security Incident Handling Guide. csrc.nist.gov
9. NIST. SP 800-86: Guide to Integrating Forensic Techniques into Incident Response, 2006.
10. NIST. SP 800-92: Guide to Computer Security Log Management, 2006.
11. IETF. RFC 3227: Guidelines for Evidence Collection and Archiving, 2002.
12. ISO/IEC 27037: Guidelines for identification, collection, acquisition and preservation of digital evidence.
13. MITRE. ATT&CK Matrix for Enterprise – Cloud (IaaS). attack.mitre.org